

NPM COOLDOWN FILE-EVENT COVERAGE

Endpoint telemetry validation for .npmrc activity before deploying privacy-preserving state snapshots.

VALIDATION QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceFileEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

09 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceFileEvents

ATT&CK

T1195.001 context

Evidence-led dossier. Query status remains an untested
implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER

01

EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Validate file-event visibility without claiming state awareness.

Elastic proved that append-only log tailing cannot reliably expose removal of min-release-age from .npmrc. Defender file telemetry can still establish whether file activity, paths and creator context exist, but it does not expose file contents.

OPERATIONAL VALUE

A bounded experiment before adding custom telemetry.

The query measures native coverage using documented fields and a controlled test. It prevents a false detection claim and identifies whether a filtered, state-based collector is necessary.

8.0

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Validation

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- min-release-age delays resolution of newly published npm versions.
- .npmrc can be rewritten in place or deleted when the last setting is removed.
- Elastic required state snapshots because filestream did not emit a reliable removal signal.

ANALYTICAL ASSESSMENT

What the evidence supports

- Defender file events may provide useful change and creator context.
- A file event cannot establish which key or value changed.
- Content-aware monitoring must filter secrets on the endpoint before transit.

DETECTION ASSUMPTIONS

What must be validated

- MDE is deployed to developer workstations.
- DeviceFileEvents records .npmrc activity on the target OS.
- Documented creator fields are populated in the tenant.

Confidence boundary

This validation does not inspect .npmrc contents and cannot prove that min-release-age was removed, weakened or bypassed. A match is not an alert and not evidence of a supply-chain compromise.

02

THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Set cooldown

A managed or developer process writes min-release-age.

02

Rewrite state file

npm or an editor modifies .npmrc in place.

03

Delete setting

The key disappears or the file is deleted.

04

Record activity

Endpoint telemetry may emit a file event.

05

Assess coverage

Analysts verify action, path and creator fields.

Observable core

Raw DeviceFileEvents for .npmrc with device, action, path and available initiating-process context.

Non-observable boundary

File body, key/value diff, min-release-age presence, effective npm version, package resolution and malicious intent.

DETECTION HYPOTHESIS

Controlled state changes should leave investigable file events.

If a process creates, rewrites, renames or deletes .npmrc, DeviceFileEvents should record the activity and available path and creator context. Legitimate activity can be classified by device owner, process, path and change record; cooldown removal still requires a filtered state snapshot.

REQUIRED TELEMETRY

DeviceFileEvents

- Microsoft Defender for Endpoint file events.
- FileName, FolderPath and ActionType.
- Device and unique event identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- Developer workstation inventory.
- npm version and endpoint-management state.
- Approved configuration jobs and owners.

UNAVAILABLE HERE

Do not infer

- File content and key/value diff.
- Snapshot history and effective cooldown.
- Private-registry token-safe parsing.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceFileEvents

DeviceFileEvents contains file creation, modification and other filesystem events with device, path, action and available initiating-process fields.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The table can establish recorded file activity. It cannot establish which configuration key changed or whether the cooldown is currently effective.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
File event	DeviceFileEvents	Primary coverage evidence.	REQUIRED
Target	FileName, FolderPath	Exact state-file identity and location.	REQUIRED
Action	ActionType	Tenant-observed event semantics.	REQUIRED
Creator	InitiatingProcessFileName, InitiatingProcessCommandLine	Process context when populated.	OPTIONAL
Account	InitiatingProcessAccountUpn, InitiatingProcessAccountName	Actor context when populated.	OPTIONAL
Previous path	PreviousFileName, PreviousFolderPath	Rename context when populated.	OPTIONAL
Event identity	Timestamp, DeviceName, ReportId	Documented unique-event tuple.	REQUIRED

Data quality requirements

- Run controlled set, rewrite and delete actions.
- Record every observed ActionType from the tenant schema.
- Measure creator-field population by OS.
- Never ingest the complete .npmrc body.

Known failure conditions

- No .npmrc event is collected.
- Creator fields remain empty.
- Retention misses the test window.
- The endpoint agent cannot observe the target filesystem.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

VALIDATION QUERY

DETECTION OBJECTIVE

Measure native .npmrc file-event coverage.

Return every recorded .npmrc file event and the documented investigation fields without assuming ActionType values or file content.

ANALYTICAL LOGIC

Direct filters and investigable output.

One exact case-insensitive filename predicate; no threshold, join, sequence, rarity, aggregation, content claim or exclusion.

KQL · UNTESTED VALIDATION

```
// npm cooldown state - endpoint file-event coverage
// Classification: Validation query - Untested implementation sketch
// Confidence: Medium
// Primary platform: Microsoft Defender XDR
// Telemetry: Microsoft Defender for Endpoint -> DeviceFileEvents
//
// This query validates whether .npmrc activity is visible and whether the
// initiating-process and path fields are populated. It does NOT inspect file
// contents and therefore cannot prove that min-release-age was removed.
// Do not convert matches into alerts. Use the results to decide whether a
// privacy-preserving state snapshot is required for reliable posture monitoring.

DeviceFileEvents
| where FileName =~ ".npmrc"
| project Timestamp,
    DeviceId,
    DeviceName,
    ActionType,
    FileName,
    FolderPath,
    PreviousFileName,
    PreviousFolderPath,
    InitiatingProcessFileName,
    InitiatingProcessCommandLine,
    InitiatingProcessAccountUpn,
    InitiatingProcessAccountName,
    SHA1,
    ReportId
| order by Timestamp desc
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested validation	None	None	DeviceName + Timestamp + ReportId	Manual triage

What a match means

Defender recorded activity affecting .npmrc and the event can be assessed for path, action and creator completeness.

What a match does not prove

Cooldown removal, weak configuration, package compromise, secret access, malicious intent or T1195.001 execution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the test action.
Map the event to the controlled set, rewrite or delete step.
- 02

Inspect event semantics.
Record ActionType, path, previous path and unique key.
- 03

Measure creator context.
Check process command line and account population.
- 04

Classify the endpoint.
Confirm developer ownership and management policy.
- 05

Decide telemetry design.
Adopt filtered state snapshots only if native events are insufficient.

Escalation gate

Do not escalate from this query alone. Escalation requires a verified state transition, unapproved actor or process, and corroborating supply-chain or credential evidence.

Primary benign overlap

npm commands, developer edits, version managers, provisioning, configuration management and security tests legitimately modify .npmrc.

INVESTIGATION PIVOTS

Device
OS, owner and MDE coverage.

File
Current path and existence.

Action
Tenant-observed value and semantics.

Process
Creator image and command line.

Account
User or management identity.

Control
npm version and enforced cooldown policy.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
npm configuration command	Expectedly writes or deletes settings.	Map to user, command and approved policy.
Configuration management	Reapplies the enterprise cooldown.	Validate tool identity and change ownership.
Developer editing	May alter registry or package settings.	Review only in controlled validation or with confirmed state evidence.

Baseline plan

- Run across a controlled validation window.
- Capture each ActionType and OS result.
- Measure path and creator completeness.
- Do not infer rarity or alert thresholds.

Validation procedure

- Execute npm config set on an isolated endpoint.
- Execute npm config delete including whole-file deletion.
- Confirm DeviceName + Timestamp + ReportId uniqueness.
- Design filtered snapshots only after the gap is proven.

TEST CASES

CASE	EXPECTED RESULT
Set min-release-age in a secret-free test file	Expected .npmrc event if covered.
Rewrite the value	Expected modification-class event if covered.
Delete the setting	Expected rewrite or deletion event if covered.
Unrelated file change	No query match.

Hunting Initial query	Candidate Current status	Production Measured precision	Optimized Stable feedback
---------------------------------	------------------------------------	---	-------------------------------------

Success

Controlled actions produce complete, stable events that support coverage measurement.

Rejection

Events exist but cannot distinguish action or creator sufficiently for investigation.

Failure

Controlled actions produce no DeviceFileEvents; native telemetry cannot support the hypothesis.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1195.001	Compromise Software Dependencies and Development Tools	Risk context only: the cooldown mitigates fresh dependency compromise. This query does not detect T1195.001.

Detection coverage summary

Strong only for validating native file-event visibility around .npmrc; no semantic coverage of the cooldown value.

Residual risk

An attacker or benign process can remove the key without a content-aware signal, while old npm versions can ignore the setting even when present.

ANALYST CONCLUSION

A valid telemetry experiment, not a supply-chain alert.

Documented Defender fields support a precise validation query. Reliable cooldown posture requires privacy-preserving state snapshots if the controlled test confirms that native file events cannot expose the key transition.

REFERENCES

- 1. Elastic Security Labs, "Tracking npm cooldown removals with Elastic Agent," 7 August 2026. <https://www.elastic.co/security-labs/npm-cooldown-removal-detection-elastic-agent>
- 2. Microsoft Learn, "DeviceFileEvents table," updated 22 June 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-devicefileevents-table>
- 3. MITRE ATT&CK, T1195.001, context only. <https://attack.mitre.org/techniques/T1195/001/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	09 August 2026	Validation	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.